

Abstract

Many cybersecurity systems focus only on one task, such as malware scanning or penetration testing, which creates gaps in protection and makes risk evaluation difficult. Treating threat modeling and penetration testing as disconnected activities can lead to incomplete or outdated security assessments. In this paper, we present the **Threat-Intelligence Based Security Assessment (TIBSA)** framework, a web-based platform that combines multi-antivirus scanning, file analysis, basic threat modeling, penetration testing support, threat intelligence integration, and continuous monitoring. The system identifies possible threats, and tests these threats using practical penetration tests. TIBSA uses external services and also applies threat mapping to connect detected threats to real-world attack techniques using threat intelligence sources. Experimental validation shows that TIBSA improves threat coverage and provides more accurate security assessments compared to traditional approaches.

Keywords : Malware Detection, Multi-Antivirus Scanning, Hybrid Analysis, Static File Analysis, Web-Based Security Tool, Cybersecurity Platform

1. Introduction

Modern organizations continue to face fragmented cybersecurity practices, where threat modeling, penetration testing, and Cyber Threat Intelligence (CTI) function as isolated activities. The increasing sophistication of adversaries and the rapid expansion of cloud-native infrastructures have amplified the need for continuous, intelligence-driven security validation. Although structured frameworks such as MITRE ATT&CK and NIST provide systematic guidance for adversary analysis and risk management, operationalizing these standards into a unified, automated security assessment workflow remains challenging. Tools such as OWASP ZAP and MISP address specific stages of the security lifecycle, yet they do not inherently integrate architectural threat analysis, empirical validation, and continuous monitoring within a single adaptive framework. This lack of integration limits continuous risk visibility and weakens proactive defense capabilities.

To address this limitation, this paper introduces the Threat-Intelligence Based Security Assessment (TIBSA) platform, an intelligence-driven framework that unifies automated STRIDE-based threat modeling, risk-oriented penetration testing, CTI enrichment, and continuous monitoring within a scalable, layered cloud-native architecture. By enabling automated threat-to-test mapping, multi-engine analysis, machine learning-assisted detection, and dynamic risk scoring, TIBSA establishes a closed-loop validation mechanism that continuously correlates architectural threats with real-world attack evidence. The proposed approach transforms security assessment from a periodic and reactive exercise into a continuous, adaptive, and data-driven cybersecurity capability. This

2. Research Problem

In recent years, there has been a noticeable rise in cybersecurity threats and cyberattacks. Protecting digital systems and files has become a major challenge. Many modern attacks use advanced malware techniques like encryption, obfuscation, and polymorphism. These methods help malicious software avoid traditional security measures. As a result, many existing protection tools struggle to detect these evolving threats, especially when they depend on outdated signature databases or a single antivirus engine. Given the increasing number of attacks in various settings, it is important to study how malware detection can be improved through practical experimentation and testing of different detection methods.

The problem is that traditional antivirus solutions that use a single scanning engine often fail to accurately detect advanced or zero-day malware. The second problem is that many current malware detection platforms are either commercial, use too many resources, or raise privacy concerns when users upload files for scanning. This project aims to develop a simulation-based web platform that combines multiple antivirus engines with static file analysis techniques like hash calculation, entropy measurement, and PE header inspection.

The system allows secure file uploads, performs hybrid multi-engine scanning, and creates unified reports that include risk assessments. By merging different detection methods, the platform seeks to improve malware identification accuracy while reducing false positives. Furthermore, the system protects user privacy by processing files temporarily and deleting them after analysis. The end result is an educational and deployable prototype that shows how hybrid malware detection systems can improve security analysis in academic and small-scale environments.

3. Literature review

New trends in cybersecurity that were explored in the papers reviewed include: automation, artificial intelligence, formal threat modeling and proactive risk-driven methodologies, all of which will assist in managing the evolving threats created through insider attacks; overloads of cyber threat intelligence (CTI) information; web application vulnerabilities; critical infrastructure vulnerabilities and uncertainty in decision-making. For example: automated correlation of asset to threat will assist in reducing the workload on analysts; automated generation of executable security tests can be generated from threat trees and STRIDE frameworks, which leads to improved discovery of vulnerabilities; the identification of insider threats via the use of machine learning-based behavioural analysis, which leads to near 100% classification accuracy; improved prioritization of risk via causal graphs using uncertainty; large language model-driven two-stage systems will lead to a 31% increase in coverage for vulnerabilities; 32% improvement in remediation effectiveness; 46% cost savings; and practical applications of threat modelling and ethical penetration testing on water grids and industrial remote terminal units. In sum, the studies provide a snapshot of the limitations of manual, reactive methods of identifying vulnerabilities and demonstrate the substantial improvements in efficiency, coverage and cost-effectiveness that

were achieved by using structured and automated techniques and intelligent technologies (i.e., ontology; agents; machine learning; large language models) to create scalable and resilient defences.

Shin et al. (2022) concluded that the TIME prototype shows it is technically possible to automate advanced CTI by linking threats, vulnerabilities, and assets. This helps manage information overload and allows for proactive defense. They pointed out several key benefits, such as smaller attack surfaces, stronger defense layers, improved agility, and conformity with NIST standards for critical infrastructure cybersecurity. However, the study mentioned that performance needs to be improved in large-scale environments. Overall, the research highlights TIME's potential to support CTI analysts by enabling timely countermeasures and teamwork in sharing intelligence against changing cyber threats [1].

Through his methodical analysis of the literature, Chauhan (2024) showed how penetration testing serves as an essential protection against insider threats by allowing organizations to do comprehensive testing that they can integrate with their analytics and training initiatives. Three key conclusions emerged from the study, demonstrating both the effectiveness of insider behavior simulation and the ongoing difficulties associated with resource constraints, future advancements in contemporary modeling methodologies, and new technical advancements. The development of multidisciplinary approaches is necessary to address issues pertaining to new security risks. According to the report, companies must conduct regular security assessments, which call for industry-wide collaborations as well as standardized security testing techniques in order to develop successful security measures through penetration testing [2].

Huang & Zhu (2024) created PenHeal, a two-stage LLM framework that autonomously executes penetration tests and creates the most effective remediation plan for identified vulnerabilities. The use of counterfactual prompting and an Instructor module allowed PenHeal to improve the following metrics compared to the baseline: Vulnerability coverage (31%), remediation effectiveness (32%), and cost reduction (46%). In summary, this research has shown how transformative LLMs can be for establishing fully automated, end-to-end self-healing cybersecurity systems and provides the basis for future research [3].

As explained by Dekker & Alevizos (2024) "The approach to visualising cyber threats via graph theory allows individuals to make better informed decisions when faced with uncertain cyber risk assessments". In this process, they began by examining how criminals employed cybercrimes before generating possible scenarios (e.g., likelihood of happening). The authors used established guidelines (e.g., new ISO standards) to create their scenarios before generating possibilities based on the knowledge gained from both above; thus, they presented a challenge in determining the level of uncertainty. Although this particular research is useful for the cybersecurity field, it provides guidance to professionals on how to anticipate and identify cyber

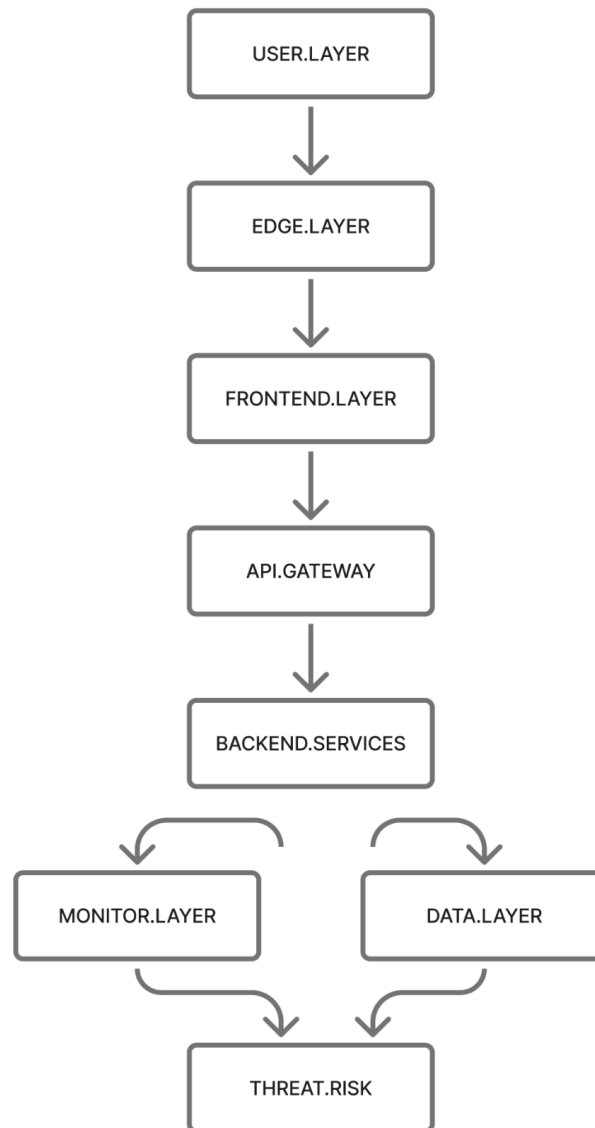
risks while optimising their use of information resources (e.g., maximising their use of all the data available) within rapidly evolving environments. [4].

OWASP ZAP (Maniraj et al. 2024) is a full-featured open-source web application vulnerability scanning tool that automates the identification of vulnerabilities, including fuzzing (automated input checks), spidering (automated navigation), and system attacks (SQL injection, XSS, and security configuration errors). Experimentally, ZAP scan performance has improved due to 1) improved ability to identify and fix security vulnerabilities, 2) thereby reducing breach risks, and 3) delivery of actionable insights on application security risks. ZAP is an effective solution for proactive testing of web applications and is an essential addition to any DevOps pipeline for the modern enterprise [5].

In their article "A Review of Automated Threat Modeling Techniques/Tools", Granata and Rak (2023) conducted a literature review of automated threat modeling techniques and compared the four open-source tools they found, one of which was Py TM, to their own method utilizing a case study for WordPress based e-commerce website. The results of their review demonstrate that the demand for automated methods to lessen reliance on experts and decrease time involved in conducting threat models will only continue to increase. Automated tools for conducting threat models provide significant improvements over traditional security assessment practices, although further challenges exist related to scalability, privacy considerations when integrating with hybrid models and across other systems [6].

In summary, recent research has demonstrated advancements in integrating threat modeling with automated security testing, penetration testing and artificial intelligence-based defence mechanisms. The literature showed a clear trend in these studies moving away from manual/static forms of testing toward intelligent/adaptive/risk-prioritized cybersecurity frameworks through the use of higher degrees of automation, predictive intelligence and decision-making via AI. Although approaches such as PrT-net automated testing, STRIDE-DFD threat modelling and risk-driven EFSM testing resulted in increased accuracy and efficiency; they frequently required a high degree of modelling expertise and suffered from scalability issues. Likewise, automation and predictive intelligence were achieved for AI-driven frameworks such as TIBSA, TIME and PenHeal through the integration of cyber-threat intelligence, however, they suffered from issues with data quality, computational load and domain-specificity. Additionally, tools like OWASP ZAP and the integration of Next Generation Firewalls demonstrated high degrees of practical effectiveness, but were impacted by false positive reports and did not cover many of the more complex attack vectors. Overall, these findings indicate the need for a unified, intelligent framework that connects automated threat modelling to AI driven prediction and dynamic penetration testing. The following chapter will identify and propose such a hybrid model in order to increase pro-active defence and optimise resource utilisation while maintaining an adaptive posture towards emerging cyber threats.

The proposed Threat Intelligent Architecture



This section presents the detailed architecture of the TIBSA platform, organized into eight distinct layers. Each layer represents a logical grouping of components with specific responsibilities, from the user-facing interfaces at the top to the core TIBSA suite at the bottom. The layered approach ensures separation of concerns, modularity, and maintainability, while enabling seamless data flow and integration between components.

x.1. LAYER 1 – User Layer

As outlined in our architectural design, the user layer, which contains several sublayers: **the Admin Portal sublayer provides administrators**

with API key management and RBAC configuration capabilities.

The security analyst console contains the dashboard for SOC analysts, threat hunters, and penetration testers to access the management interface. The client logic modules sublayer acts as the browser-side brain of TIBSA, managing the user sessions and authentication process and also having UI state management based on RBAC, API error handling, and **token refresh**, ensuring the existence of the client-side security controls. **The Customer Browser sublayer hosts the login flow, MFA, threat viewer, and user dashboard. The Client Security sublayer implements multiple layers of protection using browser-native security features and custom validators, including CSP, input validation, rate limiting, and MFA UI, acting as the first major security checkpoint in the system.**

x.2. LAYER 2 – Edge Layer

Moving forward to the edge layer as the second layer, it performs deep inspection of incoming requests by analyzing patterns associated with common web attacks. The WAF provides comprehensive protection, including SQL injection detection and blocking, cross-site scripting (XSS) prevention, CSRF token validation, path traversal detection, and malicious payload filtering. **The DDoS protection component identifies and mitigates abnormal traffic spikes and distributed denial-of-service attacks across Layers 3, 4, and 7. The TLS Termination component acts as the point where encrypted HTTPS traffic is securely decrypted before entering the application stack.** The Bot Detection Engine analyzes traffic behavior, device fingerprints, user interaction patterns, request frequency, and known malicious IP ranges to distinguish between human users and automated bots.

x.3. LAYER 3 – Frontend Layer

In the context of our proposed design, the frontend layer is basically the user-facing side of the system, plus the brain that prepares everything before it reaches the backend. It handles the dashboards, authentication, and pentest configuration **through three sub-layers: Frontend Security, which enforces CSRF token validation, XSS prevention, JWT handling, and CSP configuration; Frontend Logic, which manages authentication flows, token refresh cycles, and notification delivery; and UI Components, which renders the threat view, RBAC controls, pentest interface, logs viewer, charts, and alerts table.** All requests are secured and properly formatted before being sent to the API Gateway.

x.4. LAYER 4 – API Engine

Within the proposed framework, the API gateway serves as the central entry point for all API requests **through a single API Engine sub-layer,** providing **authentication filtering,** rate limiting, **request schema validation,** and intelligent routing to backend microservices. This critical component ensures that only valid, authenticated, and properly formatted requests reach backend services.

x.5. LAYER 5 – Backend Services

As implemented in our architecture, **the backend services layer comprises six sub-layers.** The scan service coordinates security scanning operations for URLs and files, managing the complex

workflow of analyzing potentially malicious content through multiple analysis engines. **The Sandbox sub-layer isolates and executes potentially malicious content inside a virtual machine, generating hashes, running samples, and capturing behavioral artefacts.** The Threat Intelligence Service provides threat enrichment, IOC lookups, and reputation intelligence from multiple sources using MISP and external threat feeds, including VirusTotal, HybridAnalysis, AbuseIPDB, and URLhaus, transforming raw indicators into actionable intelligence. **The Auth Service manages user authentication flows, including login, MFA verification, and token refresh operations using Authentik.** The ML Engine powers AI-driven threat detection using machine learning models for phishing and malware classification, **feature extraction, and model inference.** **The Notifications sub-layer dispatches alerts via email and webhooks to registered consumers.**

x.6. LAYER 6 – Data Storage Layer

As defined by our model, the data storage layer is basically the storage brain of the whole platform — it's where all data lives: user accounts, scans, reports, logs, and ML data. It uses PostgreSQL for structured relational data, Redis for fast caching and queues, **a dedicated ML Features DB and Scan Results DB, NoSQL storage via Elasticsearch or MongoDB for unstructured and log data, and an Audit Logs store for compliance and forensic trails.**

x.7. LAYER 7 – Monitoring & Threat Analysis

Built upon our proposed framework, Layer 7 acts as the security and monitoring brain that watches the whole platform 24/7. It collects logs

from everywhere — servers, databases, APIs, and edges — **and contains four components: the SIEM, which ingests and correlates security events; the Alert Engine, which filters and prioritizes generated alerts; the Threat Correlator, which identifies patterns across events; and the Notification Dispatcher, which shows everything in dashboards** so security and DevOps teams can see what's happening in real time.

x.8. LAYER 8 – TIBSA Suite (Core)

Layer 8 (TIBSA Suite – Level 1) is the core intelligence engine of the platform — it automates the entire threat modeling and risk analysis workflow from start to finish. **It is organized into two sub-layers: Threat Modeling & Risk Analysis, which encompasses the STRIDE + MITRE ATT&CK mapping engine, the Threat Modeling Engine, and the Risk Scoring Engine,** taking system architecture details as input, automatically building DFD diagrams, identifying threats, mapping them to MITRE ATT&CK techniques, and calculating risk scores based on likelihood and impact^{**}; and Scoring & Reporting, which includes the TTP Scoring Calculator, Custom Report Generator, and Executive Dashboard,^{**} evaluating existing security controls, prioritizing mitigation actions using cost-benefit analysis, and producing PDF/Word reports with visualizations.

Validation, Discussion, and Benchmark

To validate the TIBSA framework, a benchmark was conducted against multiple existing threat modeling and penetration testing solutions. The evaluation depended on nine security capabilities: Threat Modeling, Automation Level, Penetration Testing, Continuous Monitoring, AI/ML integration, SDLC integration, Risk Prioritization, and Threat Intelligence.

The results showed that TIBSA, like other top tools, supports Threat Modeling and enhances it through STRIDE, MITRE ATT&CK mapping and automated risk scoring, surpassing existing tools that rely on manual effort. TIBSA also achieves a very high Automation level which indicates TIBSA's ability to reduce human intervention. It also integrates Penetration Testing and Continuous Monitoring, unlike most threat modeling tools which either provide limited support or none. While tools like Cigent, ThreatModeler, and PyTM partially support SDLC integration, TIBSA incorporates these into a continuous lifecycle & ensures that security is embedded from design to deployment. TIBSA aggregates internal and external threat intelligence for decision making combined with AI & ML models phishing, malware, and insider threat detection.

Solution	Threat Modeling	Automation Level	Penetration Testing	Continuous Monitoring	AI/ML Integration	SDLC Integration	Risk Prioritization	Threat Intelligence
Microsoft TMT	✓	Medium	✗	✗	✗	Limited	Basic	✗
Cigent	✓	High	Limited	✓	Limited	✓	✓	✓
ThreatModeler	✓	High	Limited	✓	✗	✓	✓	✓
IriusRisk	✓	High	Via API	✓	Limited	✓	✓	✓
Threat Dragon	✓	Low	✗	✗	✗	Limited	Basic	✗
PyTM	✓	High	✗	Limited	✗	✓	✓	✓
Threagile	✓	High	✗	Limited	✗	✓	✓	Limited
OWASP ZAP	✗	Medium	✓	✓	Limited	✓	Basic	Limited
Metasploit	✗	Medium	✓	✗	✗	Limited	✗	Limited
Nessus	Limited	High	✓	✓	✗	Limited	✓	✓

- Limited: Partial support or requires additional configuration
- ✕ : Feature not available
- Basic: Fundamental implementation without advanced capabilities

The benchmark highlighted that traditional threat modelling tools such as Microsoft TMT and OWASP Threat Dragon provide STRIDE-based modeling but lack penetration testing capabilities, threat intelligence integration, and continuous monitoring. Similarly, platforms that focus on automation and SDLC Integration provide limited penetration testing support. In contrast, TIBSA provides comprehensive solution by combining threat modeling, penetration testing, threat intelligence and continuous monitoring making it a fully integrating and adaptive cybersecurity framework. This positions TIBSA as a superior platform that not only reduces human effort but also enables continuous security prioritization and validation across the software development lifecycle.

Reference :

[1] M. Alharbi, E. Al-Shaer, and N. Almakhdhub, "Actionable Intelligence-Oriented Cyber Threat Modeling Framework (TIME)," in Proceedings of the 55th Hawaii International Conference on System Sciences (HICSS), 2022, pp.

[2] K. Chauhan, "Insider Threats Mitigation: Role of Penetration Testing," Department of Computer Science, University of Guelph, Guelph, Canada, 2024.

[3] J. Huang and Q. Zhu, "PenHeal: A Two-Stage LLM Framework for Automated Pentesting and Optimal Remediation," arXiv preprint, vol. abs/2407.17788, 2024.

[4] M. Dekker and L. Alevizos, "A Threat-Intelligence Driven Methodology to Incorporate Uncertainty in Cyber Risk Analysis and Enhance Decision Making,".

[5] S. P. Maniraj, C. S. Ranganathan, and S. Sekar, "Securing web applications with OWASP ZAP for comprehensive security testing," Int. J. Adv. Sig. Img. Sci., vol. 10, no. 2, pp. 12-23, 2024.

[6] D. Granata and M. Rak, "Systematic analysis of automated threat modelling techniques: Comparison of open-source tools," Software Quality Journal, vol. 32, pp. 125–161, 2024.